Tema 3 · Atacantes, ataques y vulnerabilidades

SPD · Curso 2026/27 · Prof. Teodoro Rojo
Apuntes a partir de *SPD - 3. Vulnerabilidades*. "Nota" = aclaración o ejemplo añadido.

Índice

1. Atacantes: quién, por qué y cómo
2. Código malicioso (malware)
3. Protección contra el malware
4. Ataques: triángulo de la intrusión, vectores y fases
5. Herramientas
6. Tipos de ataques técnicos
7. APT y MITRE ATT&CK
8. Fraudes e ingeniería social
9. Caso práctico: WannaCry
10. Taxonomía de incidentes del ENS (CCN-STIC-817)
11. Gestión de vulnerabilidades: definiciones, ciclo de vida y ventanas
12. Clasificación (CVE, CWE) y valoración (CVSS)
13. CERT y auditoría de vulnerabilidades
14. Delitos informáticos
15. Chuleta final
16. Preguntas de repaso

1. Atacantes

1.1 ¿Quién?

Tipo	Descripción
Ciberdelincuentes y crimen organizado	Buscan dinero
Actores patrocinados por Estados	**Espionaje y sabotaje**
Hacktivistas	Motivación política, social o ideológica
Amenazas internas (*insiders*)	Empleados y exempleados
Oportunistas / *script kiddies*	Poca experiencia; usan herramientas ya hechas

1.2 ¿Por qué?

Beneficio económico (robo, extorsión, chantaje) · venganza · vandalismo · reconocimiento · reto intelectual…
Objetivos del atacante: información, identidad y dinero.

1.3 ¿Cómo? (puntos de entrada)

- Vulnerabilidades de software y **sistemas sin actualizar**.
- **Configuraciones inseguras** y servicios expuestos sin necesidad.
- **Credenciales** débiles, reutilizadas o comprometidas.
- **Ingeniería social** (debilidades humanas) y **robo de sesiones**.
- Malware y ejecución de código malicioso.
- **Criptografía débil** y protocolos obsoletos.
- Ataques a terceros y a la **cadena de suministro** de software.
- **Zero-day:** vulnerabilidad explotada **antes** de que el proveedor la conozca o de que exista corrección.

1.4 Cibercriminales

Motivación principal: **beneficio económico**. Técnicas: **extorsión** (amenaza de DoS, de publicar información robada o de destruirla), **robo de identidad/credenciales** (para suplantar o cometer fraudes), **espionaje industrial**, soborno o chantaje.

1.5 Amenazas internas (*insider threats*) (importante)

- Proceden de **empleados, exempleados, proveedores o colaboradores** que tienen o **han tenido acceso legítimo**.
- **Intencionadas** (robo, sabotaje, fraude) o **no intencionadas** (errores, negligencias, cuentas comprometidas).
- **Medidas: mínimo privilegio**, **segregación de funciones**, **revisión periódica de permisos**, **trazabilidad** y **revocación inmediata** de accesos al terminar la relación.

Nota: Conecta con el tema 1: son los principios de mínimo privilegio, *need-to-know* y la dimensión de trazabilidad.

---

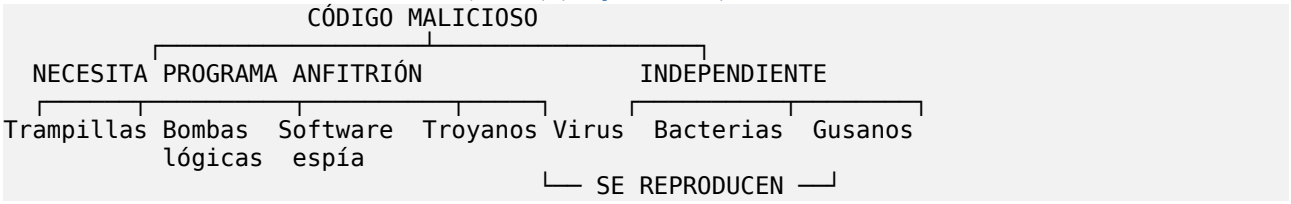
2. Código malicioso (malware)

Malware (*malicious + software*): software que, **de manera intencionada**, realiza acciones que pueden **dañar los datos o los sistemas** (UIT-T E.800). Entra por correo, intercambio de archivos, mensajería, web…

2.1 Clasificación por función

Categoría	Ejemplos
Infeccioso	Virus, gusanos
Oculto	Troyanos, rootkits, puertas traseras
Publicitario	Spyware, adware, hijackers
Robo de información	Keyloggers, *stealers*
De ataque	Botnets / zombies

2.2 Clasificación de Pelaez/Bowles (1991) (importante)



- **Necesitan anfitrión:** trampillas, bombas lógicas, software espía, troyanos, **virus**.
- **Independientes: bacterias, gusanos**.
- **Se reproducen: virus, bacterias, gusanos**.

2.3 Trampillas y bombas lógicas

Tipo	Definición
Trampilla / puerta trasera (*trapdoor*, *backdoor*)	Mecanismo de acceso que **elude la autenticación o autorización** normales
Bomba lógica (*logic bomb*)	Código que actúa cuando se cumple una **condición** (fecha, evento, borrado de una cuenta…)
Huevo de Pascua (*Easter egg*)	Funcionalidad oculta, normalmente **recreativa**. **No es necesariamente malware** (ej.: buscar "Do a barrel roll" en Google)

Salvaguarda: revisión de código.

Nota: Ejemplo típico de bomba lógica: un administrador despedido deja un script que borra la base de datos si su usuario desaparece del sistema.

2.4 Spyware, adware y hijackers

Tipo	Qué hace
Spyware	**Recoge información** del usuario **sin consentimiento** (hábitos de navegación, cookies…)
Adware	Muestra **publicidad** sin consentimiento
Browser hijacker	**Cambia la configuración del navegador** (página de inicio, buscador…)

Salvaguardas: anti-spyware, filtros de publicidad, firewalls.

2.5 Troyanos y rootkits (importante)

- **Troyano:** programa que **aparenta ser legítimo o útil** pero esconde funciones maliciosas. Suele instalarse con un **usuario privilegiado**; al ejecutarse hace lo que no debe.
- **Rootkit (encubridor): oculta** procesos, archivos, usuarios o accesos, haciéndose pasar por programas legítimos, mientras deja **puertas traseras** abiertas.
- Ambos **dificultan la detección**.
- Ejemplos: keyloggers, zombies (para DDoS), NetBus.
- Vector: correo, web…
- **Salvaguardas: EDR**/antimalware, **control de aplicaciones**, **mínimos privilegios**, actualizaciones y monitorización.

Nota: Diferencia clave: un troyano **no se reproduce** (a diferencia de virus y gusanos).

2.6 Ransomware (importante)

Malware para **extorsionar** cifrando la información, robándola o amenazando con divulgarla.

- **Vectores de entrada:** phishing, explotación de vulnerabilidades, credenciales robadas, accesos remotos comprometidos. Suelen **meter prisa** a la víctima.
- **Modalidades:**

Modalidad	Qué hace el atacante
Extorsión simple	Cifra y pide rescate
Doble extorsión	Cifra **y** amenaza con publicar los datos
Extorsión sin cifrado	Solo roba la información y amenaza con divulgarla

- **Salvaguardas: MFA**, **copias de seguridad aisladas o inmutables**, EDR, **segmentación de red**, gestión de parches, procedimientos de respuesta… y **sensatez**.

Nota: Con doble extorsión, tener backups **no basta**: aunque recuperes los datos, siguen amenazando con publicarlos.

2.7 Virus, bacterias y gusanos (importante)

Programas que **se reproducen a sí mismos** y suelen intentar esconderse.

Tipo	Definición	Clave
Virus	**Modifica otros programas** insertando una copia de sí mismo; el programa infectado propaga la infección. **Puede mutar**	Necesita anfitrión
Bacteria	Se replica **consumiendo los recursos** del sistema	Independiente; causa DoS

Tipo	Definición	Clave
Gusano (*worm*)	**Programa independiente** que se reproduce y **se envía por la red**	Independiente; se propaga solo

Gusanos famosos: **Morris (1988)**, ILoveYou, Klez, Code Red, SQL Slammer, IKEE.B, Welchia, Conficker, Lemon Duck, Bondat… **Salvaguardas:** antivirus, parches, firewall, políticas de seguridad.

---

3. Protección contra el malware

Tres tipos de medidas:

Preventivas	Correctivas	Reactivas
Mantenerse informado de fraudes	**Limpiar** sistemas infectados	Activar el **procedimiento de respuesta a incidentes**
Actualizar SO, programas y navegadores	**Reinstalar** el SO y actualizarlo	Pedir apoyo a un **CERT/CSIRT** (ej.: **INCIBE, línea 017**)
No aceptar archivos de procedencia desconocida	**Restaurar** la información	**Denunciar** ante las autoridades / FCSE
Antimalware actualizado y **firewall**	Antes de limpiar: **aislar** el equipo, **evaluar el alcance** y **preservar evidencias**; recuperar de copias **verificadas** y comprobar que se eliminó la causa	
Copias de seguridad		
Desconfiar de mensajes que **meten prisa, adulan, regalan o amenazan**		
No fiarse solo del enlace al pasar el ratón: **verificar el dominio real**; **HTTPS no garantiza que la web sea legítima**		

Fases de la respuesta a incidentes: detección → análisis → contención → erradicación → recuperación → lecciones aprendidas.

Nota: Conecta con los tipos de control del tema 1: preventivo, correctivo/recuperativo y detectivo.

---

4. Ataques

4.1 Triángulo de la intrusión (importante)

Para que haya un ataque hacen falta **tres** elementos a la vez:

Elemento	Ejemplos
Motivos	Diversión, animadversión, lucro personal
Medios	Conocimientos, herramientas
Oportunidad	**Fallos en la seguridad**

Nota: La organización no puede controlar los motivos ni los medios del atacante; **lo que sí puede reducir es la oportunidad** (corrigiendo fallos de seguridad).

4.2 Vectores de ataque (ESET Security Report 2020)

- **Quién:** atacante externo, atacante interno, **empleado descuidado**.
- **Cómo:** ingeniería social, explotación de vulnerabilidades, ataques directos/físicos.
- **Por dónde:** servicios web, escritorio remoto / acceso a servidores, cuentas corporativas, **exceso de información pública**, configuraciones inseguras.
- **Consecuencias:** accesos y usos indebidos de la infraestructura, **robo de información**, privacidad de la información, **interrupción de operaciones**.

4.3 Principales vectores de acceso inicial

1. **Ingeniería social y phishing.**
2. Explotación de **servicios expuestos a Internet**.
3. **Credenciales comprometidas.**
4. Aplicaciones y dispositivos **sin actualizar**.
5. Ataques a **proveedores y cadena de suministro**.
6. **Dispositivos externos** (USB) y accesos físicos.

4.4 Fases de un ataque (importante)

#	Fase	Detalle
1	**Descubrimiento y exploración**	**Reconocimiento / *footprinting*** (pasivo y activo) y **recolección / *fingerprinting***. **OSINT** (*Open Source Intelligence*)
2	**Búsqueda de vulnerabilidades**	
3	**Explotación** (con *exploits*) y acceso	
4	**Obtención de privilegios**	Escalada
5	**Compromiso del sistema**	Puertas traseras, nuevas cuentas… y búsqueda de nuevos objetivos (*pilfering*)
6	**Eliminación de pruebas**	Borrar logs, bloquear la monitorización…

Pentesting = pasos **1 a 4** + **corrección** y **formación** (un auditor no compromete ni borra pruebas).

Nota: *Footprinting* = recopilar información general del objetivo (dominios, IPs, empleados). *Fingerprinting* = identificar sistemas concretos (SO, versiones de servicios). **Google Dorks** = búsquedas avanzadas en Google para encontrar información expuesta.

4.5 PTES (*Penetration Testing Execution Standard*)

Guía para tests de intrusión en **7 pasos**:

1. **Acuerdo previo** (alcance, permisos)
2. **Recolección de información**
3. **Modelado de amenazas**
4. **Análisis de vulnerabilidades**
5. **Explotación**
6. **Post-explotación**
7. **Informe de resultados**

Nota: El acuerdo previo es lo que separa un pentest legal de un delito (ver art. 197 bis del Código Penal, apartado 14).

---

5. Herramientas

Función	Herramientas
Descubrimiento de activos y puertos	**Nmap**
Análisis de tráfico	**Wireshark, tcpdump**
Evaluación de vulnerabilidades	**Greenbone/OpenVAS, Nessus**
Auditoría web	**Burp Suite, OWASP ZAP**
Validación de vulnerabilidades	**Metasploit**
Auditoría de contraseñas	**John the Ripper, Hashcat**
Análisis y correlación	**SIEM**, **EDR** (*Endpoint Detection and Response*), *threat hunting*

Nota: En la Práctica 1 ya usaste **tcpdump** para comprobar el enmascaramiento y el cifrado del túnel.

---

6. Tipos de ataques técnicos

Lista del profesor: (1) análisis de tráfico, (2) repetición, (3) suplantación, (4) alteración del encaminamiento, (5) XSS, (6) inyección de código, (7) DoS, (8) DDoS, (9) fraudes, engaños y extorsiones.

6.1 Análisis de tráfico (*eavesdropping*)

- **Ataque pasivo**: analiza los datos que circulan por la red buscando sistemas, servicios, información sensible, hábitos de usuarios…
- Se limita con **switches y VLAN**. **Atención:** Pero ojo con el **MAC flooding**: llenar la tabla MAC del switch para que actúe como un *hub* y reenvíe todo a todos los puertos.

6.2 Ataques de repetición (*replay*) (importante)

- **Capturar y retransmitir un mensaje válido** para que el receptor lo vuelva a aceptar. **No hace falta modificarlo.**
- Permite autenticación fraudulenta, entregar información incorrecta, generar tráfico…
- Ejemplos: reutilizar **tokens**, peticiones de autenticación o **transacciones** capturadas.
- **Contramedidas: números de secuencia, nonces, marcas temporales, tokens de un solo uso** y mecanismos criptográficos **ligados a la sesión**.

Nota: Es exactamente lo que evitan T_1/T_2 y el reto V en el escenario KDC del tema 2.

6.3 Suplantación (*spoofing*) (importante)

Tipo	Cómo	Variantes / notas
IP spoofing	Falsear la **IP de origen**	Ocultación/suplantación de identidad; **secuestro de conexiones** (*hijacking*); **ARP spoofing / ARP poisoning** → **Man-in-the-Middle**
DNS spoofing	**Respuestas DNS falsas** para desviar al usuario (o provocar DoS)	Alterar la configuración del *resolver* del cliente; redirigir las peticiones a otro servidor; alterar los datos del propio servidor DNS
SMTP spoofing	Correos con **remitente falso**	*Relay* abierto, engañar a destinatarios, spam, dañar la reputación del supuesto remitente. **Defensas: SPF, DKIM y DMARC**
Identity spoofing	Usar las **credenciales** de otro usuario	Keyloggers (software o hardware), *snoopers* (buscan URLs con identidades), sniffers, ingeniería social, **fuerza**

Tipo	Cómo	Variantes / notas
		bruta / diccionario

Nota: SPF = registro DNS con los servidores autorizados a enviar correo del dominio. **DKIM** = firma digital del correo con la clave del dominio. **DMARC** = política que dice qué hacer si fallan SPF/DKIM y a quién informar.

6.4 Alteración del encaminamiento

Desviar el tráfico para que pase por otros sistemas o redes:

- **Encaminamiento fuente** (*source routing*): para analizar redes y routers, o como **ruta de retorno** en IP spoofing.
- **Alterar tablas de encaminamiento**: **ICMP Redirect**, mensajes falsos de **RIP, OSPF, EIGRP o BGP**.

6.5 Cross-Site Scripting (XSS) (importante)

Vulnerabilidad que permite **ejecutar código no confiable en el navegador** de un usuario **dentro del contexto de una aplicación web**.

Modalidad	Cómo funciona
Reflejado	El contenido malicioso se **devuelve en la respuesta** (p. ej. en un parámetro de la URL)
Almacenado	Queda **guardado** (comentario, perfil…) y se muestra a **otros usuarios**
Basado en DOM	El **código del cliente** (JavaScript) procesa datos no confiables de forma insegura

- **Consecuencias: robo/suplantación de sesiones**, manipulación del contenido, acceso a información.
- **Prevención: APIs seguras** (escapar/codificar la salida) y **CSP** (*Content Security Policy*) como defensa adicional.

Nota: Ejemplo típico: un buscador que muestra "Resultados para: *[lo que escribiste]*" sin escaparlo; si el texto contiene una etiqueta `<script>`, el navegador la ejecuta.

6.6 Inyección SQL (importante)

Aparece cuando **datos controlados por el usuario** pueden **alterar la estructura** de una consulta SQL.

```
SELECT * FROM usuarios WHERE username = '$username'
-- Entrada maliciosa:  pepito'; DROP TABLE users; --
-- Consulta resultante:
SELECT * FROM usuarios WHERE username = 'pepito'; DROP TABLE users; --'
```

- **Consecuencias:** leer, modificar o borrar información sin autorización y, a veces, **comprometer el sistema**.
- **Contramedidas: consultas parametrizadas** (separar instrucciones SQL y datos), **mínimo privilegio** en las cuentas de BBDD, **validación de la entrada**.

Nota: Consulta parametrizada (Java): `PreparedStatement ps = con.prepareStatement("SELECT * FROM usuarios WHERE username = ?"); ps.setString(1, username);` → el valor nunca se interpreta como SQL.

6.7 Denegación de servicio (DoS) (importante)

Degrada un servicio o lo hace **inaccesible** a los usuarios legítimos, por sobrecarga de la red o de los recursos, o por desconfiguración:

- Muchas conexiones simultáneas, grandes volúmenes de datos…
- Alterar DNS o el encaminamiento.
- **Bacterias** que consumen recursos.
- **Mail bombing** (envío masivo de correo).

- **Incumplir las reglas de un protocolo:**

Ataque	Cómo
Ping de la muerte	Mensajes ICMP **de más de 64 KB** (tamaño ilegal)
SYN flood	Iniciar muchas conexiones TCP (SYN), a menudo desde IPs falsas, **sin completar el *three-way handshake*** → la víctima agota su tabla de conexiones semiabiertas
Inundación ICMP	Enviar muchísimas peticiones ICMP
Smurf	Peticiones ICMP con **IP origen falsificada (la de la víctima)** enviadas a la **dirección de difusión** → todos los equipos de esa red responden a la víctima
Cierre de conexiones TCP	Enviar segmentos **RST** falsos

6.8 DDoS (distribuida)

- **Ataques DoS simultáneos y coordinados** desde **cientos o miles** de sistemas.
- A menudo los equipos atacantes **no saben que participan** (**zombies, botnets**).
- **Mitigación:** filtrado de tráfico, **limitación de peticiones** (*rate limiting*), **CDN**, **WAF**, servicios anti-DDoS especializados, coordinación con los proveedores de conectividad.

---

7. APT y MITRE ATT&CK

7.1 APT (*Advanced Persistent Threats*) (importante)

Ataques **sofisticados** para acceder a sistemas **concretos** y extraer información o provocar un mal funcionamiento.

- **Avanzados: dirigidos** a objetivos concretos; combinan métodos (incluidos **zero-day**); seguimiento e interacción continuos.
- **Persistentes:** enfoque **lento y sigiloso**; intentan permanecer **invisibles** el mayor tiempo posible.
- Ejemplos: Titan Rain, **Stuxnet**, Aurora/Hydraq, Shady RAT, Sykipot, Flame, Mahdi, Duqu, Red October, **Mask (Careto)**, Snake…

Nota: Stuxnet (2010) saboteó centrifugadoras del programa nuclear iraní; Careto es un APT de habla hispana descubierto en 2014.

7.2 MITRE ATT&CK

- **Base de conocimiento** con las **tácticas y técnicas** observadas en ataques reales.
- Relaciona las fases de una intrusión con técnicas concretas: **acceso inicial, ejecución, persistencia, escalada de privilegios, evasión, movimiento lateral y exfiltración**.
- **Usos:** análisis de amenazas, **diseño de controles** y evaluación de la **capacidad de detección**.

---

8. Fraudes e ingeniería social

8.1 Fraudes, engaños y extorsiones

Tipo	Definición
Phishing	Engañar para que se acceda a **webs falsas que imitan las originales**
Pharming	Variante: aunque escribas la URL **legítima**, el navegador va a la **falsa** (alterando el **DNS** o el **fichero hosts**)
Ransomware	Cifrar archivos y pedir rescate
Extorsiones	Amenaza de publicar datos confidenciales o

Tipo	Definición
	difamatorios

Nota: Diferencia: en el **phishing** tú haces clic en un enlace falso; en el **pharming** escribes bien la dirección y aun así acabas en la web falsa.

8.2 Ingeniería social (importante)

- **Manipulación** de la tendencia natural de las personas **a confiar**.
- Objetivo: que el usuario **colabore con el atacante**. **Muy eficaz y difícil de controlar.**

  "Es tan efectiva que raramente tengo que usar un ataque técnico" — **Kevin Mitnick**
- Explota debilidades humanas: **confianza, generosidad, codicia, curiosidad, afán de protagonismo**…
- **Protección: concienciación y normas.**

Técnica	En qué consiste Nota:
Phishing	Por correo electrónico
Vishing	Por **voz** (llamada telefónica)
Smishing	Por **SMS**
Baiting	Dejar un **cebo** (p. ej. un USB "olvidado")
Pretexting	Inventar un **pretexto** o personaje creíble ("soy del soporte técnico…")
Quid pro quo	Ofrecer algo **a cambio** de información

8.3 Otras técnicas no técnicas

- ***Shoulder surfing***: mirar por encima del hombro, escuchar.
- ***Tailgating***: entrar **detrás** de un usuario autorizado.
- Usar **estaciones desbloqueadas**.
- Buscar contraseñas **escritas a la vista**.
- Probar contraseñas **inexistentes, obvias o fáciles**.
- ***Dumpster diving***: buscar en la **basura**.

---

9. Caso práctico: WannaCry (importante)

Dato	Valor
Fecha	**12 de mayo de 2017**
Tipo	**Ransomware** (*WanaCrypt0r 2.0*) y **gusano** → *crypto worm*
Qué hacía	Cifraba ficheros (.doc, .jpg, .pdf…) y pedía **300 USD en Bitcoin**
Entrada inicial	Spam masivo con enlace de descarga del malware
Propagación interna	Vulnerabilidad de **SMB** de Windows: ***EternalBlue*** (**CVE-2017-0145**), buscando e infectando equipos vulnerables
Parche	Microsoft lo publicó el **14 de marzo de 2017** (**MS17-010**, KB 4013389)
Exploit público	Mediados de **abril de 2017**
¿Zero-day?	**NO**: el parche existía **dos meses antes**

Lección: casi todos los infectados **no habían parcheado**. Además, **los parches requieren reiniciar el equipo** para aplicarse.

Nota: Es el ejemplo perfecto de **ventana de vulnerabilidad conocida** (apartado 11.3): el parche existía, pero los sistemas no lo tenían instalado.

---

10. Taxonomía de incidentes del ENS (CCN-STIC-817)

Clasificación	Tipos de incidente
Contenido abusivo	SPAM · delito de odio · contenido sexual o violento inadecuado
Contenido dañino	Sistema infectado · servidor **C&C** (mando y control) · distribución de malware · configuración de malware · dominio **DGA** (generado por algoritmo para contactar con el C&C)
Obtención de información	**Escaneo** de redes (*scanning*) · análisis de paquetes (*sniffing*) · ingeniería social
Intento de intrusión	Explotación de vulnerabilidades **conocidas** (con CVE) · intento de acceso con vulneración de credenciales (fuerza bruta) · ataque desconocido
Intrusión	Compromiso de cuenta **con** privilegios · **sin** privilegios · compromiso de aplicaciones (p. ej. **inyección SQL**) · **robo** (intrusión física)
Disponibilidad	DoS · DDoS (SYN flood, reflexión/amplificación UDP) · **sabotaje** físico · **interrupciones** externas (desastre natural)
Compromiso de la información	Acceso no autorizado · modificación no autorizada (incl. cifrado por ransomware) · **pérdida de datos**
Fraude	Uso no autorizado de recursos · derechos de autor (*warez*) · suplantación · **phishing**
Vulnerable	**Criptografía débil** (POODLE/FREAK) · **amplificador DDoS** (DNS *open resolvers*, NTP *monlist*) · servicios con acceso no deseado (**Telnet, RDP, VNC**) · revelación de información (**SNMP, Redis**) · sistema vulnerable (WPAD, versiones desfasadas)
Otros	Otros · **APT** · ciberterrorismo · daños informáticos a **PIC** (infraestructuras críticas)

Nota: Para memorizar las 10 clases: **"Contenido abusivo y dañino, obtienen información, intentan intrusión, intrusión, disponibilidad, compromiso, fraude, vulnerable y otros."**

---

11. Gestión de vulnerabilidades

11.1 Definiciones (UIT-T X.1205) (importante)

- **Vulnerabilidad: punto débil o deficiencia** de un sistema de información que pone en riesgo la seguridad. Puede estar **en el código** o deberse a una **configuración inadecuada**. Permite comprometer la **confidencialidad, integridad o disponibilidad**.
- **Explotación:** ejecutar software, alterar datos o ejecutar comandos/acciones para **aprovechar una vulnerabilidad** y conseguir un comportamiento no deseado.
- **Atención: No todas las vulnerabilidades son explotables.**

Nota: Un **exploit** es precisamente ese código o secuencia que aprovecha la vulnerabilidad.

11.2 Ciclo de vida de una vulnerabilidad (INTECO)

Fase	Riesgo
1. **Creación** (se introduce el fallo)	Bajo
2. **Descubrimiento y publicación**	Bajo
3. **Explotación**	Medio

Fase	Riesgo
4. **Desarrollo del parche o *hotfix***	**Alto**
5. **Difusión de la actualización**	Bajo

Nota: El riesgo es máximo mientras se desarrolla el parche: la vulnerabilidad ya es pública y se explota, pero aún no hay solución.

11.3 Ventana de vulnerabilidad (importante)

Intervalo de tiempo en el que un sistema es vulnerable (por un defecto, una mala configuración, etc.):

Ventana	Desde...	Hasta...	Responsable de cerrarla
Desconocida (*unknown window*)	Se **descubre** la vulnerabilidad	Se **conoce** y existe **parche**	Fabricante
Conocida (*known window*)	El fabricante **publica el parche**	El sistema **se parchea**	**Nosotros** (administradores)

11.4 Ataque de día cero y ventana de exposición

Línea temporal:

```
Vulnerabilidad → Exploit en  → Descubierta por → Revelada     → Firmas    → Patch    → Patch
introducida      circulación   el fabricante     públicamente   antivirus   lanzado    implementado
                 |←——— ATAQUE DE DÍA CERO ———→|←———— SEGUIMIENTO EN ATAQUES ————→|
|←———————————— VENTANA DE EXPOSICIÓN (días, meses o incluso años) ————————————→|
```

- **Pre zero-day:** la vulnerabilidad la conoce **el investigador**, pero aún no la ha comunicado a nadie.
- **Zero-day:** se ha dado a conocer **a terceros** (fabricante, delincuentes...) pero **aún no es pública**.

---

12. Clasificación y valoración de vulnerabilidades

12.1 CVE y CWE

- Cada **fabricante** tiene su propia clasificación (p. ej. MS17-010 de Microsoft).
- **CVE** (*Common Vulnerabilities and Exposures*, cve.mitre.org): **nomenclatura normalizada** para identificar vulnerabilidades: **`CVE-año-número`** (ej.: **CVE-2017-0145**).
- **CWE** (*Common Weakness Enumeration*): **tipos de debilidades** (taxonomía). Ej.: CWE-79 = XSS, CWE-89 = inyección SQL.

Nota: CVE = una vulnerabilidad concreta en un producto concreto. **CWE = el tipo de error** que la provoca.

12.2 ¿Qué riesgo supone una vulnerabilidad?

Factores: puntuación del fabricante · **criticidad** de los sistemas afectados · **nº de sistemas** afectados · **exposición** de esos sistemas. Para medir la criticidad (de baja a crítica) se usa el **CVSS**.

12.3 CVSS (*Common Vulnerability Scoring System*) (importante)

Marco **estandarizado** (mantenido por **FIRST**) para **puntuar** las vulnerabilidades conocidas **de 0 a 10**. El resultado es una **puntuación** y un **vector** (cadena con los valores de cada métrica).

Tres grupos de métricas (CVSS v3.1, 2020):

Grupo	Qué representa	¿Obligatorio?
Base	Características **intrínsecas**; no	**Sí**

Grupo	Qué representa	¿Obligatorio?
	dependen del entorno **ni del tiempo**. Explotabilidad, impacto y ámbito	
Temporales (amenazas)	Lo que **cambia con el tiempo** pero no depende del entorno	Opcional
De entorno (ambientales)	Lo **propio de un entorno concreto**; las fijan los **usuarios finales**	Opcional

Métricas base (v3.1)

Grupo	Métrica	Valores
Explotabilidad	**AV** – Vector de ataque	**N**etwork / **A**djacent / **L**ocal / **P**hysical
	AC – Complejidad del ataque	**L**ow / **H**igh
	PR – Privilegios requeridos	**N**one / **L**ow / **H**igh
	UI – Interacción del usuario	**N**one / **R**equired
Ámbito	**S** – *Scope* (¿afecta a otros componentes?)	**U**nchanged / **C**hanged
Impacto	**C / I / A** – Confidencialidad, Integridad, Disponibilidad	**H**igh / **L**ow / **N**one

Nota: La diapositiva pone los valores de impacto como "completo / parcial / ninguno", que es la terminología de **CVSS v2**; en **v3.1** son **Alto / Bajo / Ninguno**.

Métricas temporales

Métrica	Valores
E – Madurez del *exploit*	No definida / Teórica (no probada) / Prueba de concepto / Funcional / Alta
RL – Nivel de corrección	Solución oficial / Temporal / No oficial (alternativa) / No disponible
RC – Credibilidad del informe	Desconocida / Razonable / Confirmada por el fabricante

Métricas de entorno

- **CR / IR / AR**: requisitos de **confidencialidad, integridad y disponibilidad** del activo en *tu* organización (Alto / Medio / Bajo).
- **Métricas base modificadas**: las mismas métricas base, ajustadas a tu entorno.

Nota: Rangos de severidad (v3.x):

Puntuación	Severidad
0.0	Ninguna
0.1 – 3.9	**Baja**
4.0 – 6.9	**Media**
7.0 – 8.9	**Alta**
9.0 – 10.0	**Crítica**

Nota: Ejemplo de vector — Log4Shell (CVE-2021-44228), puntuación 10.0:
`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H` → explotable **por red**, **fácil**, **sin privilegios**, **sin interacción**, **cambia de ámbito** e impacto **alto** en C, I y A. El peor caso posible.

CVSS v4.0 — novedades (importante)

Cambio	Detalle
Nueva métrica de explotabilidad	**AT – Requisitos de ataque** (*Attack Requirements*)

Cambio	Detalle
Desaparece el ámbito (*Scope*)	Se sustituye por el impacto en **sistemas posteriores** (*Subsequent System*: SC, SI, SA), además del impacto en el **sistema vulnerable** (VC, VI, VA)
Temporal → *Threat*	Solo queda **Exploit Maturity**; se retiran *Remediation Level* y *Report Confidence*
Nuevo grupo suplementario	*Automatable*, *Recovery*, *Safety*, *Value Density*, *Vulnerability Response Effort*, *Provider Urgency*. **Informa pero no cambia la puntuación**

Recursos: calculadora CVSS (nvd.nist.gov/vuln-metrics/cvss/v3-calculator) y **NVD** (*National Vulnerability Database* del NIST, nvd.nist.gov/vuln/search).

---

13. CERT y auditoría de vulnerabilidades

13.1 CERT

CERT (*Computer Emergency Response Team*): centro de **respuesta a incidentes** formado por expertos en TI.

- **Misión: evitar, ayudar a contener y minimizar los daños** de los incidentes (medidas preventivas y reactivas).
- Estudia el estado global de la seguridad, **responde a incidentes**, **publica alertas** sobre amenazas y vulnerabilidades y ofrece información para mejorar la seguridad.
- **Servicios:** información, protección, soporte y formación.

CERT	Ámbito
INCIBE-CERT (antes CERTSI) + **OSI** (Oficina de Seguridad del Internauta)	Ciudadanos y empresas (España)
CCN-CERT	**Administraciones públicas** (Centro Criptológico Nacional, del **CNI**)
US-CERT / CISA	Agencia de ciberdefensa de EE. UU.
CERT/CC	Universidad **Carnegie Mellon** (el primero, creado tras el gusano Morris)

Nota: CERT y **CSIRT** (que aparecía en NIS, tema 1) son prácticamente sinónimos.

13.2 Auditoría de vulnerabilidades

- **Evaluación sistemática** de las debilidades de nuestros sistemas → **detección temprana**.
- Detecta puntos explotables **desde dentro** (usuarios con cuenta) y **desde fuera**.
- **Objetivo:** mejorar la seguridad y **reducir las ventanas de vulnerabilidad**.
- Se adopta el **punto de vista del atacante** (***Red Team***).
- Muy **automatizable**: Nessus/OpenVAS, Saint, Retina…

Pasos:

1. **Inventario** de sistemas y servicios → mapa de red, escaneo de IPs y puertos.
2. **Instalar** herramientas automáticas → basadas en **red** o en **host**.
3. **Identificar** debilidades visibles y explotables → test de vulnerabilidades conocidas.
4. **Medidas correctoras e informe** → política de parches, eliminar servicios innecesarios, contraseñas seguras…

Limitaciones de los escáneres automáticos:

- Dan una **foto puntual**, no continua → hay que **repetir** los escaneos.
- **Solo detectan vulnerabilidades conocidas.**

- Necesitan **intervención humana** (preparar y **interpretar**: falsos positivos y negativos).
- **Pueden afectar a los servicios** evaluados.

Nota: Falso positivo = el escáner avisa de una vulnerabilidad que no existe. **Falso negativo** = existe y no la detecta (el más peligroso).

---

14. Delitos informáticos

14.1 Convenio de Budapest

- **Convenio sobre la Ciberdelincuencia del Consejo de Europa** (Budapest, **23/11/2001**): **primer tratado internacional** en la materia. Ratificado por **España en 2010**; abierto a cualquier país.
- **Ejes: legislación penal común** y **cooperación internacional**.
- Delitos: contra la **confidencialidad, integridad y disponibilidad** (acceso, interceptación, interferencia, abuso de dispositivos), **delitos informáticos** (falsificación, fraude), relacionados con el **contenido** (pornografía infantil), con la **propiedad intelectual**, y la tentativa y complicidad.

14.2 Código Penal español (reforma 31/03/2015, en vigor 01/07/2015) (importante)

Artículo	Conducta	Pena
197 bis.1	**Acceder** (o facilitar el acceso) a un sistema **vulnerando las medidas de seguridad** y sin autorización, o **mantenerse** en él contra la voluntad del titular	Prisión **6 meses – 2 años**
197 bis.2	**Interceptar** transmisiones no públicas de datos (incluidas emisiones electromagnéticas) sin autorización	Prisión **3 meses – 2 años** o multa de 3 a 12 meses
197 ter	**Producir, adquirir, importar o facilitar** a terceros **programas** pensados para esos delitos, o **contraseñas/códigos de acceso**	Prisión **6 meses – 2 años** o multa de 3 a 18 meses

Otros delitos del Código Penal: revelación de secretos (197) y de **secretos de empresa** (278, 279) · **daños informáticos** (264…) · falsedades informáticas · **estafa informática (248.2)** · defraudación de telecomunicaciones · ciberdelitos sexuales (183 ter) · propiedad intelectual (270) · honor (205, 208, 211) · amenazas y coacciones · odio y apología del terrorismo (510, 578).

Nota: Por eso un pentest **siempre** necesita **autorización por escrito** (el "acuerdo previo" del PTES).

Unidades policiales: Policía Nacional — **Brigada Central de Investigación Tecnológica (BCIT)**; Guardia Civil — **Grupo de Delitos Telemáticos (GDT)**.

14.3 Recursos

- Informes públicos del **CCN-CERT**, **SANS Institute**.
- Listas de seguridad: **Full-Disclosure**, boletines de Microsoft, **Una al Día (Hispasec)**, avisos de **INCIBE**, **WeLiveSecurity (ESET)**.
- Libros: *El arte del engaño* (Mitnick, 2002), *El arte de la intrusión* (Mitnick, 2005), *El arte de la invisibilidad* (Mitnick, 2017), *El huevo del cuco* (Clifford Stoll, 1989), *Vigilancia permanente* (Snowden, 2019).

---

15. Chuleta final

Concepto	En una frase
Virus	Se copia **dentro de otros programas**
Gusano	Programa **independiente** que se **propaga por la**

Concepto	En una frase
	red
Bacteria	Se replica **agotando recursos**
Troyano	Parece útil, esconde algo malo; **no se reproduce**
Rootkit	**Oculta** la presencia del atacante
Bomba lógica	Se activa con una **condición**
Ransomware	**Cifra/roba** y pide **rescate**
Replay	**Reenvía** un mensaje válido capturado
Spoofing	**Falsea** una identidad (IP, DNS, correo, usuario)
XSS	Ejecuta **script en el navegador de otro**
SQLi	Los datos **cambian la consulta SQL**
SYN flood	Conexiones TCP **a medias**
Smurf	ICMP a **broadcast** con la IP de la víctima
APT	Ataque **dirigido, sigiloso y largo**
Phishing / Pharming	Enlace falso / **DNS** o hosts falseados
Ventana conocida	De que sale el **parche** a que **lo instalo**
Zero-day	Explotada **antes de que haya parche**
CVE / CWE	**Vulnerabilidad concreta** / **tipo de debilidad**
CVSS	Puntuación **0–10**: base + temporal + entorno

16. Preguntas de repaso

1. Tipos de atacantes y sus motivaciones. ¿Qué medidas protegen de las amenazas internas?
2. Clasifica según Pelaez/Bowles: virus, gusano, troyano, bomba lógica, bacteria. ¿Cuáles se reproducen? ¿Cuáles necesitan anfitrión? *Solución:* Se reproducen: virus, bacteria, gusano. Necesitan anfitrión: virus, troyano, bomba lógica.
3. Diferencia entre virus y gusano. Pon dos ejemplos de gusanos.
4. ¿Qué es un rootkit y por qué es peligroso?
5. Modalidades de ransomware. ¿Por qué los backups no bastan contra la doble extorsión?
6. Medidas preventivas, correctivas y reactivas ante malware. Fases de la respuesta a incidentes.
7. Triángulo de la intrusión. ¿Sobre qué vértice puede actuar la organización?
8. Fases de un ataque. ¿Qué pasos incluye un pentest? ¿Cuáles son los 7 pasos del PTES?
9. Asocia herramienta y función: Nmap, Wireshark, OpenVAS, Burp Suite, Metasploit, Hashcat.
10. ¿Qué es un ataque de repetición y cómo se evita?
11. Tipos de spoofing. ¿Para qué sirven SPF, DKIM y DMARC?
12. XSS: modalidades y prevención.
13. Explica una inyección SQL con un ejemplo y cómo se evita.
14. Explica el SYN flood y el ataque Smurf.
15. DoS vs DDoS. Medidas de mitigación de DDoS.
16. ¿Qué hace "avanzada" y "persistente" a una APT?
17. Phishing vs pharming. Técnicas de ingeniería social (vishing, smishing, baiting, pretexting…).
18. WannaCry: cómo entraba, cómo se propagaba, ¿fue un zero-day? ¿Qué lección deja?
19. Ventana de vulnerabilidad conocida vs desconocida. Pre-zero-day vs zero-day.
20. CVE vs CWE. ¿Qué formato tiene un CVE?
21. Grupos de métricas de CVSS v3.1 y métricas base. Interpreta el vector `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`. *Solución:* explotable por red, baja complejidad, sin privilegios, sin interacción, ámbito sin cambios, impacto alto en C, I y A (puntuación 9.8, crítica).
22. ¿Qué cambia en CVSS v4.0?
23. Pasos de una auditoría de vulnerabilidades y limitaciones de los escáneres.
24. ¿Qué castiga el art. 197 bis del Código Penal? ¿Por qué un pentest necesita autorización?